

# Security+ 2.3 · Memory Injections

Mestre CyberSec — Guia Completo CompTIA Security+ (SY0-701) · **Aula 2.3 — Memory Injections (2:39)** · [Vídeo Oficial no YouTube ↗](#) · [Página no Professor Messer ↗](#)

---

**Resumo Executivo da Aula:** DLL injection: força processo legítimo a carregar biblioteca maliciosa; process hollowing: substitui a memória de um processo legítimo rodando. Antivírus por assinatura não pega (o processo é 'legítimo'), só EDR behavioural.

## Highlights que a prova cobra

---

- DLL injection: processo carrega DLL do atacante
- Process hollowing: shellcode substitui código de processo suspenido

## Dicas de prova & Cenários Típicos

---

- 'malicious code runs inside a legitimate process's memory' = process hollowing / DLL injection

**Cenário clássico de exame:** Cenário: 'malware é executado dentro do processo do antivírus do sistema' = DLL injection / hollowing.

## 🔔 Além do Vídeo: O que a CompTIA cobra na prova (Conceitos, Siglas e Armadilhas da Aula 2.3 — Memory Injections)

**Por que este aprofundamento é cobrado no exame?** O vídeo do Professor Messer apresenta uma introdução ágil. Porém, a banca oficial CompTIA Security+ (SY0-701) exige raciocínio de engenharia prática e cobra diretamente os seguintes protocolos, jargões e ferramentas no contexto desta aula:

- **Princípio do Menor Privilégio:** Usuários e sistemas devem ter apenas as permissões estritamente necessárias para suas funções corporativas.
- **Defesa em Profundidade (Defense-in-Depth):** Aplicação de múltiplas camadas de controles (técnicos, administrativos, físicos) para evitar que a falha de um exponha todo o ambiente.

### ⚠️ Armadilhas e Pegadinhas Clássicas da Banca:

- Nunca decore apenas letras ou siglas: a CompTIA altera o cenário exigindo que você justifique por que o controle escolhido é o *MAIS adequado* dentre 4 opções válidas.
- Fique atento às restrições do enunciado: 'sem custo adicional' favorece configurações nativas do SO; 'maior granularidade de rede' favorece TACACS+ em vez de RADIUS; 'não-repúdio' exige chave privada/assinatura digital.

## ✅ Perguntas de treino comentadas (10 questões)

Gabarito com resolução passo a passo e análise técnica individual de cada distrator no fim. Tente responder antes de olhar.

**1. Atacante entra como usuário comum e vira 'Domain Admin'. Esse ganho de poder é:**

- A)** Escalada de privilégio (privilege escalation)
- B)** Negação de serviço
- C)** Engenharia social
- D)** Sniffing

**2. Cenário corporativo (Memory Injections):** Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'DLL injection: processo carrega DLL do atacante'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: DLL injection: processo carrega DLL do atacante...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

**3. Cenário corporativo (Memory Injections):** Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'Process hollowing: shellcode substitui código de processo suspenso'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Process hollowing: shellcode substitui código de processo suspenso...

**4. Cenário corporativo (Memory Injections):** Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'malicious code runs inside a legitimate process's memory' = process hollowing / DLL injection'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: 'malicious code runs inside a legitimate process's memory' = process hollow...

**5. Cenário corporativo (Memory Injections):** Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'Cenário: 'malware é executado dentro do processo do antivírus do sistema' = DLL injection / hollowing.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Cenário: 'malware é executado dentro do processo do antivírus do sistema' =...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

**6. Cenário corporativo (Memory Injections):** Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'DLL injection: processo carrega DLL do atacante'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: DLL injection: processo carrega DLL do atacante...

**7. Cenário corporativo (Memory Injections):** Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'Process hollowing: shellcode substitui código de processo suspenso'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: Process hollowing: shellcode substitui código de processo suspenso...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

**8. Cenário corporativo (Memory Injections):** Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'malicious code runs inside a legitimate process's memory' = process hollowing / DLL injection'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: 'malicious code runs inside a legitimate process's memory' = process hollow...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

**9. Cenário corporativo (Memory Injections):** Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'Cenário: 'malware é executado dentro do processo do antivírus do sistema' = DLL injection / hollowing.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Cenário: 'malware é executado dentro do processo do antivírus do sistema' =...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

**10. Cenário corporativo (Memory Injections):** Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'DLL injection: processo carrega DLL do atacante'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: DLL injection: processo carrega DLL do atacante...

## GABARITO COMENTADO COM ANÁLISE DETALHADA DOS DISTRADORES

### 1) A — Escalada de privilégio (privilege escalation).

✓ **Por que está certa:** A escalada de privilégio (privilege escalation) é a técnica na qual um atacante, após obter acesso inicial com um usuário comum, explora vulnerabilidades, falhas de configuração ou credenciais mal protegidas para elevar seu nível de permissão dentro do sistema. No contexto do CompTIA Security+ (SY0-701), esse conceito é classificado como uma tática de pós-exploração (TA0004 no MITRE ATT&CK) e pode ser vertical (de usuário comum para administrador) ou horizontal (de um usuário para outro com privilégios semelhantes). O enunciado descreve exatamente a transição de 'usuário comum' para 'Domain Admin', que é o exemplo clássico de escalada vertical de privilégios em ambientes Windows Active Directory. Portanto, a opção correta é a que identifica esse movimento como privilege escalation.

#### ✗ **Por que as outras estão erradas:**

- *Negação de serviço:* Negação de serviço (DoS) é um ataque que visa tornar um recurso, serviço ou rede indisponível para usuários legítimos, geralmente por meio de sobrecarga de requisições, esgotamento de recursos ou exploração de falhas que causam travamento. No cenário descrito, o atacante não está tentando derrubar o serviço, mas sim obter mais poder dentro do domínio. A negação de serviço não envolve elevação de privilégios; ela afeta a disponibilidade, não a confidencialidade ou integridade das permissões. Portanto, não se aplica ao ganho de poder de usuário comum para Domain Admin.
- *Engenharia social:* Engenharia social é a manipulação psicológica de pessoas para que revelem informações confidenciais ou executem ações que comprometam a segurança, como clicar em links maliciosos ou fornecer credenciais. Embora a engenharia social possa ser um vetor inicial para obter acesso, ela não descreve o processo técnico de elevação de privilégios dentro do sistema. O enunciado foca no ganho de poder após o acesso, não no método de obtenção inicial. Portanto, engenharia social não é a classificação correta para a transformação de usuário comum em Domain Admin.
- *Sniffing:* Sniffing (ou eavesdropping) é a interceptação passiva de tráfego de rede para capturar dados sensíveis, como credenciais em texto claro ou informações de sessão. É uma técnica de coleta de informações, não de elevação de privilégios. Mesmo que o sniffing possa levar à obtenção de credenciais administrativas, ele não é o ato de escalar privilégios em si. O enunciado descreve o resultado final (tornar-se Domain Admin), não o método de captura de tráfego. Portanto, sniffing não é a resposta correta para classificar o ganho de poder.

### 2) A — Implementar a solução correspondente: DLL injection: processo carrega DLL do atacante....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Memory Injections): DLL injection: processo carrega DLL do atacante.

#### ✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

**3) D — Implementar a solução correspondente: Process hollowing: shellcode substitui código de processo suspenso....**

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Memory Injections): Process hollowing: shellcode substitui código de processo suspenso.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

**4) D — Implementar a solução correspondente: 'malicious code runs inside a legitimate process's memory' = process hollow....**

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Memory Injections): 'malicious code runs inside a legitimate process's memory' = process hollowing / DLL injection.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

**5) C — Implementar a solução correspondente: Cenário: 'malware é executado dentro do processo do antivírus do sistema' =....**

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Memory Injections): Cenário: 'malware é executado dentro do processo do antivírus do sistema' = DLL injection / hollowing..

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

**6) D — Implementar a solução correspondente: DLL injection: processo carrega DLL do atacante....**

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Memory Injections): DLL injection: processo carrega DLL do atacante.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

**7) B — Implementar a solução correspondente: Process hollowing: shellcode substitui código de processo suspenso....**

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Memory Injections): Process hollowing: shellcode substitui código de processo suspenso.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

**8) A — Implementar a solução correspondente: 'malicious code runs inside a legitimate process's memory' = process hollow....**

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Memory Injections): 'malicious code runs inside a legitimate process's memory' = process hollowing / DLL injection.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

**9) C — Implementar a solução correspondente: Cenário: 'malware é executado dentro do processo do antivírus do sistema' =....**

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Memory Injections): Cenário: 'malware é executado dentro do processo do antivírus do sistema' = DLL injection / hollowing..

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

**10) D — Implementar a solução correspondente: DLL injection: processo carrega DLL do atacante....**

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Memory Injections): DLL injection: processo carrega DLL do atacante.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.